

REV	DATA	APROVAÇÃO	
4	09/02/2026	Gerente de SOC	

SUMÁRIO

1. OBJETIVO.....	2
2. DEFINIÇÕES.....	2
3. CONTROLES ASSOCIADOS A ESTE PROCEDIMENTO.....	3
4. RESPONSABILIDADE E AUTORIDADE.....	3
5. FASES DA RESPOSTA A INCIDENTES DE SI.....	4
5.1 Identificação e comunicação de eventos.....	4
5.2 Triagem.....	4
5.3 Análise de incidentes.....	5
5.4 Contenção, erradicação e recuperação de incidente.....	7
5.5 Relato de incidentes.....	9
5.6 Comunicação de incidentes.....	9
6. REFERÊNCIAS.....	11
Anexo 1 – Exemplos de incidentes de SI.....	12
Anexo 2 – Orientações sobre a estimativa do nível de impacto de incidentes com dados pessoais.....	13
Anexo 3 – Orientações sobre evidências digitais.....	14

1. OBJETIVO

Estabelecer as ações para resposta a incidentes de segurança da informação, que ocorram no âmbito das operações da Interjato Serviços de Telecomunicações Ltda. e Interjato Telecom Ltda.

2. DEFINIÇÕES

ANATEL: Agência Nacional de Telecomunicações

ANPD: Autoridade Nacional de Proteção de dados

CIS: Comunicação de Incidente de Segurança

CSI: Comitê de Segurança da Informação

Dado pessoal (DP): informação relacionada a pessoa natural identificada ou identificável; Informações podem ser consideradas DP pelo menos nos seguintes casos:

- se elas contêm ou estão associadas a um identificador que se refere a uma pessoa natural (por exemplo, ao número do CPF);
- se elas contêm ou estão associadas a um identificador que pode ser relacionado a uma pessoa natural (por exemplo, uma conta bancária);
- se elas contêm ou estão associadas a um identificador que pode ser utilizado para estabelecer uma comunicação com uma pessoa natural identificada (por exemplo, uma localização geográfica precisa, um número de telefone);
- se elas contêm uma referência que liga os dados a qualquer dos identificadores acima.

As informações também serão consideradas DP se contiverem ou estiverem associadas a uma característica que distingue uma pessoa natural de outras pessoas naturais (por exemplo, dados biométricos).

- **Evento de segurança da informação** – qualquer ocorrência observável em um sistema ou rede.
- **Incidente de segurança da informação** – Evento ou conjunto de eventos indesejados ou inesperados relacionados à segurança da informação que resultem ou tenham potencial concreto de resultar em violação da confidencialidade, integridade ou disponibilidade das informações, bem como em impactos às operações, aos ativos ou à continuidade do negócio. Incidentes de segurança da informação podem ser deliberados, como ataques cibernéticos, infecção por malware, exploração de vulnerabilidades ou uso indevido de credenciais, ou acidentais, decorrentes de erros humanos não intencionais, falhas de processos, configurações inadequadas, falhas tecnológicas ou eventos ambientais. Podem envolver fatores técnicos e/ou não técnicos, conforme exemplificado no [Anexo 2](#)).
- **LGPD**: Lei Geral de Proteção de dados (Lei Nº 13709, de 14/08/2018).
- **SI**: Segurança da Informação
- **SOC (Security Operation Center) ou Centro de Operações de Segurança**: Setor responsável por centralizar os serviços relacionados à segurança da informação, especialmente aqueles de natureza técnica.

3. CONTROLES ASSOCIADOS A ESTE PROCEDIMENTO

- 5.24 - Planejamento e preparação da gestão de incidentes da segurança da informação.
- 5.25 - Avaliação e decisão sobre eventos da segurança da informação.
- 5.26 - Resposta a incidentes de segurança da informação.
- 5.27 - Aprendizado com incidentes de segurança da informação.
- 5.28 - Coleta de evidências.
- 6.08 - Relato de eventos de segurança da informação.

4. RESPONSABILIDADE E AUTORIDADE

Ação	Responsabilidade	Autoridade
Identificar e comunicar eventos de segurança da informação que podem constituir um incidente	Todos os colaboradores	
Realizar a triagem de eventos e decidir se constituem um incidente de SI	SOC/CSI, conforme natureza do evento	
Classificar o incidente de SI, de forma a priorizar seu tratamento		
Tratamento de incidentes de SI		

5. FASES DA RESPOSTA A INCIDENTES DE SI

5.1 Identificação e comunicação de eventos

Todos os colaboradores poderão comunicar eventos de segurança da informação através de formulários no [Microsoft forms](#).

Além disso, os seguintes sistemas de monitoramento são capazes de identificar eventos de SI:

- Kaspersky
- CERT.br
- Abuse
- Suporte Técnico
- SIEM/EDR

Estes sistemas são capazes de detectar e reportar anormalidades, de acordo com seus parâmetros de configuração.

5.2 Triagem

De acordo com a natureza do evento (ver exemplos no [Anexo 1](#)), as comunicações serão recebidas e analisadas pelo:

- **CSI** – No caso de eventos de natureza não-técnica
- **SOC** – Para eventos de natureza técnica

O propósito da triagem é entender o que foi relatado, de forma a decidir se o evento é um incidente de SI e, caso seja, determinar a gravidade do incidente.

Para caracterizar um evento de SI como incidente, os responsáveis devem avaliar se houve ou qual o potencial para ocorrer impactos na integridade, confidencialidade e disponibilidade da informação e qual tipo de informação foi ou poderia ser impactada.

Caso o julgamento decida que o impacto é normal (ou seja, faz parte das variações inerentes aos processos e sistemas), o evento não será considerado incidente e o monitoramento continua sem nenhuma ação adicional. Caso seja considerado incidente, o tratamento deve prosseguir a partir do [item 5.3](#) deste documento.

Os critérios utilizados para decidir sobre a natureza do evento e para classificar aqueles que foram considerados incidentes (de forma a priorizar seu tratamento) estão apresentados no quadro 1:

Classificação	Tipo de informação envolvida	Impacto nas atividades
Muito importante	• Informações confidenciais, que incluem dados pessoais sensíveis • Informações críticas para o fornecimento dos principais serviços	• Muitos ou todos os serviços estão bloqueados • Grande volume de informação está exposta, por exemplo, envolvendo grande percentual de titulares de dados pessoais • Há perda financeira substancial
Importante	• Informações confidenciais, que incluem dados pessoais sensíveis • Informações críticas para o fornecimento dos principais serviços	• Alguns serviços estão bloqueados ou muito prejudicados • Parte de informação está exposta • Há perda financeira relevante
Moderado	• Informações confidenciais, que podem envolver dados pessoais não sensíveis. • Informações importantes para a realização de atividades internas	• O desempenho dos serviços principais está levemente prejudicado. • O vazamento de informações é pequeno • A perda financeira é pequena
Baixo	Informações confidenciais, sem envolver dados pessoais	O impacto nos serviços principais é pequeno
Normal	Informações não confidenciais	Não há impacto perceptível nos principais serviços.

Quadro 1 – Critérios para triagem de eventos

5.3 Análise de incidentes

A análise de incidentes deve ser realizada para tentar verificar quais são a causa e o efeito de um incidente.

Podem ser utilizados diferentes tipos de análises técnicas. Por exemplo:

- **Análise de sistema:** que inclui a aquisição, preservação e análise de artefatos do sistema (por exemplo, arquivos de log ou informação do registro) que possam auxiliar na determinação da causa do incidente e no desenvolvimento de roteiros de ação;

- **Análise de rede:** o processo de coletar, examinar e interpretar tráfego de rede para identificar e responder aos eventos que violam a política de segurança ou o comportamento dos recursos conectados à rede, ou à infraestrutura de rede;
- **Análise de malware:** identificação, análise e caracterização de artefatos reportados de software (por exemplo, assinaturas de vírus, *worms*, cavalos de Troia etc.), suspeitos de terem atuado no incidente.
- **Análise forense:** para obter informação relativa à tecnologia e à metodologia forense de computadores.
- **Entrevistas com envolvidos:** realizar entrevistas com colaboradores e partes relevantes para obter informações detalhadas sobre o incidente, identificar o escopo, possíveis causas e impacto nas operações;
- **Análise de acessos físicos:** examinar registros de acesso físico (ex.: monitoramento por vídeo) a áreas restritas e registros de visitantes, para rastrear eventos suspeitos ou não autorizados.

Freqüentemente, não existem linhas de separação claras os tipos de análise. Por exemplo, uma pessoa analisando um sistema, usando análise de sistema, pode descobrir traços de malware no sistema. O mesmo é verdadeiro para uma pessoa usando análise de rede.

O quadro 2 apresenta exemplos de informações típicas que podem ser utilizadas na investigação de um incidente:

Ativo	Fonte da informação	Informações para uso em análise
Sistemas de computador	Sistema de estação de trabalho	Verificar o sistema operacional e o tempo/ <i>status</i> dos processos, informação de rede, usuários/grupos, compartilhamento de informação, informação de <i>login</i> .
		<i>Rootkit</i> (processo, rede, checagem de registro oculto).
		Análise de registro, execução automática, análise de eventos/ <i>log</i> , data de criação do sistema de arquivos, análise do método de intrusão, arquivos temporários de <i>Internet</i> .
	Sistema do servidor	Códigos maliciosos detectados e/ou programas de <i>hackers</i>
		Informação do sistema (por exemplo, tipo de sistema operacional, versão, uso, serviços), informação de processos, portas e arquivos abertos, informação de rede, usuários que acessaram.
		Arquivo de senhas, arquivo de log, <i>rootkit</i> , arquivos relacionados a hackers
Rede		Coleta de dados para cada tipo de incidente (uso de recursos ilegais, DDoS, perda e modificação de dados, informação exposta).
		Pacotes, estatísticas de tráfego, pacotes

Banco de dados	decodificados.
	Padrões de ataque, causa de sobrecarga
	Uso da senha-padrão, acesso remoto.
	Permissão e/ou autorização de acesso, lista de controle de acesso

Quadro 2 – Informações típicas utilizadas em análise de incidentes

Durante a análise de incidentes, várias evidências (como arquivos de log, informação sobre processos, status de conexão de rede, conteúdo de arquivos, metadados etc.) são coletadas. É importante que sejam preservadas em segurança para futura referência e eventual uso em processos judiciais (ver detalhes no [Anexo 3](#)).

5.4 Contenção, erradicação e recuperação de incidente

a) Contenção

As ações de contenção devem fornecer uma solução de segurança razoável até que informações suficientes sejam coletadas para solucionar as vulnerabilidades e os danos. Algumas ações de contenção podem ser tomadas durante a fase de resposta preliminar de um ciclo de vida de manipulação de incidentes e outras podem ser tomadas após uma análise aprofundada, que pode identificar sistemas mais afetados ou atividades maliciosas.

As etapas de contenção também podem ser executadas iterativamente com as etapas na fase de detecção e análise.

Exemplos de estratégias comuns de contenção que podem ser usadas:

- **Implementar bloqueios (*Firewall*):** o IP do *gateway* e os bloqueios de portas são usados para impedir a disseminação de comprometimento de um sistema externo identificado ou de vetores de ataque. Os exemplos de bloqueios de *firewall* incluem endereços IP que hospedam códigos maliciosos, software não autorizado, retransmissões de correio, criadores de *phishing* e *spam* ou endereços IP e *hosts* hostis conhecidos. Os bloqueios de e-mail incluem a filtragem de anexos, linhas de assunto e remetentes. Os bloqueios de URL e domínio são usados para impedir o acesso a websites ou hosts não autorizados ou maliciosos.
- **Desconectar (isolar, remover):** a desconexão de um sistema que foi infectado da área de rede local pode ajudar a prevenir infecções do restante da rede. A desconexão do sistema da Internet ou de qualquer outra rede pública pode ajudar a impedir o acesso de entrada, o tráfego de saída ou a extração de dados. A desconexão ou isolamento do host e/ou o segmento de rede afetado do resto da rede podem ajudar a evitar mais contaminações ou a conter atividades maliciosas em um sistema ou segmento de rede lógico. Isto permite que os sistemas conectados continuem funcionando, mas não irá espalhar atividades maliciosas para o restante da infraestrutura. Em alguns casos, isto pode ser relevante para monitorar atividades maliciosas, enquanto limita a capacidade da ameaça de atacar outros sistemas.
- **Desligar:** se for determinado que permitir que o sistema funcione irá destruir dados ou aplicativos no sistema, pode ser necessário desligar o sistema como uma medida de contenção. Se for determinado que um servidor específico, como um e-mail ou servidor da web, precisa ser desligado até que os problemas possam ser eliminados ou conter a

disseminação de código malicioso, convém que o servidor específico seja desligado. Atentar para que, além de destruir dados não voláteis, o desligamento de um servidor pode afetar adversamente vários usuários e operações ou serviços críticos.

- **Mudanças de roteamento:** eliminar a rota do invasor para o ambiente, impedindo que o invasor acesse recursos próximos que possam ser alvos. Bloquear os mecanismos de transmissão do código malicioso entre sistemas infectados.
- **Desativação de conta:** desabilitar contas de usuário que podem ter sido usadas no ataque.

Importante: quaisquer alterações nos sistemas comprometidos, incluindo ações de contenção, podem destruir as informações requeridas para avaliar a causa de uma invasão. Deve-se assegurar que todos os dados necessários para análise sejam completamente coletados antes de fazer alterações no sistema. Além disso, coletar e proteger todas as evidências necessárias em uma investigação subsequente antes de executar qualquer ação de contenção (ver [Anexo 3](#)).

b) Erradicação

Erradicação é a eliminação de componentes do incidente, como código malicioso, contas e senhas comprometidas, ou outros sistemas e informações comprometidos. O objetivo da erradicação é remover permanentemente os dados armazenados digitalmente em alguma forma de mídia.

Exemplos de estratégias comuns de erradicação que podem ser usadas:

- formatação do disco rígido;
- utilização de ferramentas de limpeza de mídia para apagar completamente o disco rígido;
- destruição física.

c) Recuperação

Recuperação é a restauração de um serviço, dados ou sistema ao seu estado operacional normal.

Exemplos de estratégias comuns de recuperação que podem ser usadas:

- reconstruir sistemas a partir de backups limpos;
- reconstruir sistemas do zero;
- alterar contas e senhas;
- aplicar ações contra a recorrência;
- aplicar atualizações e *patches* do sistema;
- recuperar a continuidade de negócios de outro site

5.5 Relato de incidentes

Finalizada a resposta ao incidente, caso o mesmo tenha sido classificado como **muito importante**, o SOC ou o CSI deverá elaborar um relatório, indicando:

- Descrição do incidente
- A causa raiz do incidente
- Medidas adotadas para resposta ao incidente
- Pontos do plano de resposta que não funcionaram adequadamente e medidas a serem adotadas para introduzir melhorias
- Tempo de reação entre a descoberta do incidente e o início do gerenciamento do incidente
- Se houve notificações e comunicações sobre o incidente e para quem
- Impacto financeiro, reputacional e operacional do incidente na empresa. No caso de incidentes envolvendo DP, é preciso destacar se ocorreu os seguintes impactos:
 - Danos morais.
 - Danos materiais.
 - Violação à integridade física.
 - Discriminação social.
 - Danos reputacionais.
 - Roubo de identidade.
 - Engenharia social / Fraudes.
 - Limitação de acesso a um serviço.
 - Exposição de dados protegidos por sigilo profissional/legal.
 - Restrições de direitos.
 - Perda de acesso a dados pessoais.

O registro será feito conforme a metodologia do PG-06 no sistema Bitrix.

5.6 Comunicação de incidentes

Dependendo do contexto e das características do incidente, pode ser necessário gerar relatórios para partes interessadas, como clientes¹, fornecedores e autoridades etc.

O CSI poderá sugerir quais informações sobre o incidente de SI serão comunicadas ao público interno e externo e como isso será feito. Entretanto, no âmbito da LGPD, se o incidente envolver dados pessoais, poderá haver necessidade de comunicação à ANPD e aos titulares de DP.

5.6.1 – Comunicação à ANPD

O Art. 48 da LGPD impõe aos controladores o dever de comunicar aos titulares e à ANPD a ocorrência de incidentes que possam causar **riscos ou danos relevantes** aos titulares (ver anexo 2 para orientações sobre a estimativa do nível de impacto).

A comunicação de incidentes de segurança à ANPD deve ser realizada pelo encarregado pela proteção de dados (DPO) por meio do formulário eletrônico CIS, disponibilizado no site da ANPD.

A diretoria e a assessoria jurídica devem ser envolvidas em todos os casos em que seja necessária a comunicação de incidentes de segurança à ANPD.

5.6.2 – Comunicação aos titulares de DP

¹ A descrição resumida dos incidentes e seu tratamento pode fazer parte do Relato de Serviços (ver IT -09)

O comunicado aos titulares deve utilizar linguagem clara e conter, ao menos, as seguintes informações²:

- resumo e data de ocorrência do incidente;
- descrição dos dados pessoais afetados;
- riscos e consequências aos titulares de dados;
- medidas tomadas e recomendadas para mitigar seus efeitos, se cabíveis;
- dados de contato do controlador para obtenção de informações adicionais sobre o incidente.

A comunicação pode ocorrer:

- Por comunicado individual por escrito (mensagem eletrônica/carta/e-mail etc.)
- Comunicado individual por escrito com confirmação de recebimento (mensagem eletrônica/carta/e-mail etc.)
- Ampla divulgação do fato em meios de comunicação, por iniciativa própria
- Anúncio público no site eletrônico, mídias sociais ou aplicativos da empresa.

Caso a comunicação seja individual, será necessário contabilizar quantos titulares foram comunicados. Caso a comunicação não seja feita de forma individual, deverá existir uma justificativa adequada.

5.6.3 – Comunicação à ANATEL

O Art.17 da Resolução ANATEL Nº 740, de 21/12/2020 exige que a prestadora realize junto à Anatel, a notificação dos incidentes relevantes que afetem de maneira substancial a segurança das redes de telecomunicações e dos dados dos usuários, além disso, menciona que a notificação do incidente relevante deve incluir análise da causa e do impacto, bem como ações de mitigação adotadas, conforme o caso.

6. REFERÊNCIAS

NBR ISO/IEC 27035-3 – Tecnologia da informação — Gestão de incidentes de segurança da informação. Parte 3: Diretrizes para operações de resposta a incidentes de TIC

NBR ISO/IEC 27037 - Tecnologia da informação — Técnicas de segurança — Diretrizes para identificação, coleta, aquisição e preservação de evidência digital

NBR ISO/IEC 29134 - Tecnologia da informação — Técnicas de segurança — Avaliação de impacto de privacidade — Diretrizes

7. ANEXOS

Anexo 1 – Exemplos de incidentes de SI

a) Natureza não-técnica

² Estas informações são necessárias para o caso de notificação à ANPD

- Perda ou furto de equipamentos (celulares, computadores, etc...).
- Perda ou furto de documentos impressos.
- Incidentes envolvendo informação impressa (Ex.: danos que tornem o documento ilegível).
- Divulgação não-autorizada de informação confidencial (por e-mail, redes sociais, conversas etc...).
- Acesso físico a áreas não autorizadas.
- Outras Violações nas políticas de segurança de informação.

b) Natureza técnica

- Ataque de negação de serviço (*Distributed Denial of Service* – DDoS).
- Vírus e *worms*.
- Ataques com *ransomware*.
- Ataques de *phishing*.
- Acesso não-autorizado a um sistema interno
- Ataque de injeção SQL
- Interceptação de tráfego: Ataques *Man-in-the-Middle* (MITM)
- Acesso não-autorizado à conta de controle de domínio de site ou serviço online (Sequestro de Domínio)
- Quebra de Controle de Acesso: Broken Access Control
- Falsificação de requisições por parte do servidor: Server-Side Request Forgery
- Falsificação de requisições por parte de usuário: Cross-Site Request Forgery
- Injeção de XSS: Cross-Site Scripting
- Engenharia Social
- Ataques do tipo Insider
- Execução de Scripts de forma remota: Remote Code Execution
- Falsificações de Requisição de DNS: DNS Spoofing
- Inserção de arquivos de forma local ou remota: Local File Inclusion e Remote File Inclusion

Anexo 2 – Orientações sobre a estimativa do nível de impacto de incidentes com dados pessoais

Nível	Descritivo
1	Incidentes que envolvem DP acessíveis ao público (por exemplo, em páginas na internet)
2	Incidentes que envolvem DP que requerem um interesse legítimo de acesso (por exemplo, arquivos públicos restritos)
3	Incidentes que envolvem DP cuja divulgação não autorizada pode afetar a reputação do titular (por exemplo, informações sobre renda, benefícios de bem-estar social, imposto sobre propriedade ou multas)
4	Incidentes que envolvem DP cuja divulgação, modificação, perda ou destruição não autorizada pode afetar a existência ou a saúde, a liberdade e a vida do titular de DP (por exemplo, informações sobre compromisso com uma instituição, uma sentença, análises de pessoal, dados de saúde, dívidas não atendidas ou se o titular de DP corre o risco de se tornar uma vítima em um processo criminal)

A escala acima, que aborda a natureza do DP, pode ser combinada com a análise do impacto que o incidente pode causar no titular:

Nível	Descritivo
1	Os titulares de DP não serão afetados ou poderão encontrar alguns inconvenientes , os quais serão superados sem nenhum problema (tempo gasto reinserindo informações, aborrecimentos, irritações etc.)
2	Os titulares de DP podem encontrar inconvenientes significativos , que eles serão capazes de superar, apesar de algumas dificuldades (custos extras, negação de acesso a serviços de negócios, medo, falta de entendimento, estresse etc.).
3	Os titulares de DP podem encontrar consequências significativas , que podem ser capazes de superar, embora com sérias dificuldades (apropriação indevida de fundos, lista negra de bancos, danos à propriedade, perda de emprego, intimação etc.)
4	Os titulares de DP podem encontrar consequências significativas, ou mesmo irreversíveis , que não podem superar (dificuldades financeiras, como dívidas não prestáveis ou incapacidade de trabalhar, doenças físicas ou psicológicas a longo prazo etc.)

Por fim, a quantidade de titulares de DP afetados também pode influenciar na determinação do nível de impacto de um incidente.

Anexo 3 – Orientações sobre evidências digitais

Comumente, evidência digital é governada por três princípios fundamentais: relevância, confiabilidade e suficiência. Estes três princípios são importantes para todas as investigações, não apenas para que aquelas evidências digitais sejam admitidas nos tribunais.

A evidência digital é relevante quando se destina a provar ou refutar um elemento de um caso específico que está sendo investigado. Ou seja, que há uma boa razão para coletar a evidência.

O significado geral do princípio da confiabilidade é “para garantir que a evidência digital seja o que pretende ser”. O processo de coleta de evidência deve ser passível de auditoria e repetições.

Nem sempre é necessário coletar todos os dados ou realizar uma completa cópia da evidência digital original. O conceito de suficiência significa que é necessário coletar potencial evidência digital suficiente para permitir que elementos da questão sejam adequadamente examinados ou investigados. O entendimento deste conceito é importante para priorizar o esforço apropriado quando o tempo ou o custo são preocupações.

No processo de coleta de evidências, é necessário documentar todas as ações, incluindo a identificação das evidências obtidas.

Evidência digital pode ser frágil na sua natureza. Ela pode ser alterada, adulterada ou destruída por manuseio ou exame impróprio. É recomendado que quem manuseia evidência digital seja competentes para identificar e administrar os riscos e consequências advindos de possíveis linhas de conduta quando tratam com a evidência digital. Falha em manusear dispositivos digitais adequadamente podem tornar a potencial evidência digital contida naqueles dispositivos digitais inutilizáveis.